

GitHub Copilot への質問：Password について ¹

0.1 問題

安全で覚えやすい Password, Pass Phrase(Passkey) について

- Password, Passkey どちらが安全ですか？
- 異なるアカウント事に Password, Pass Phrase(Passkey) は変えるべきですか？
- 作り方で重視すべきキーポイントを 10 個程度示してください.
- それらをかなりみたすパスワードと記憶法の例を 10 個位挙げて下さい.

0.2 追加問題

- 最近記憶力に自信がありません. 保管法について良い方法があれば 5 個位挙げて下さい
- どれ位の期間で変更するべきですか？

0.3 ペルソナ・オーディエンスペルソナ

情報セキュリティの専門家としてお答えください.

スマホやインターネットはよく使っているが, 情報セキュリティには詳しくない年寄りへの説明をお願いします.

0.4 出力

markdown でお願いします.

¹これは質問への著作権の主張です. 私に回答への著作権はありません. また, 回答の信頼性についてもいかなる保証も出来かねます. なお, このファイルは markdown での応答を pandoc で latex に変換したものです.

Password, Passkey について

GitHub Copilot

1 回答

1.1 1. パスワード、パスフレーズ、パスキーの違い

1.1.1 結論

安全性と使いやすさを総合すると、次の順でおすすめします。

1. パスキー (Passkey)
2. パスワードマネージャーで生成・保存した長いパスワード
3. ランダムな単語を組み合わせたパスフレーズ
4. 自分で考えた短いパスワード

ここでいう「パスキー」は、WebAuthn/FIDO2 方式のログイン機能を指します。単なる「パスワードの別名」ではありません。

1.1.2 パスキー

パスキーは、スマートフォンやパソコンの指紋認証、顔認証、端末の暗証番号などを使ってログインする仕組みです。

長所

- パスワードを覚える必要がない
- 偽サイトに入力して盗まれるフィッシング攻撃に強い
- サービス側に通常のパスワードを保存しない
- サービスごとに異なる暗号鍵が使われる
- 生体情報そのものが Web サイトに送られるわけではない

注意点

- 対応していないサービスもある
 - スマートフォンやパソコンを紛失した場合に備え、復旧手段を設定する必要がある
 - Apple、Google、Microsoft などのアカウント自体を強固に保護する必要がある
- 対応している重要なサービスでは、パスキーを優先してください。

1.1.3 パスワードとパスフレーズ

パスフレーズは、複数の単語を組み合わせた長い認証文字列です。短く複雑なパスワードよりも、十分に長く、サービスごとに異なるパスフレーズの方が安全で覚えやすい場合があります。

青い電車-砂時計-柚子-北極星-417!

上記は説明用の例なので、実際には使用しないでください。

1.2 2. アカウントごとに変えるべきか

必ず変えてください。

同じパスワードを複数のサービスで使うと、1つのサービスからパスワードが漏れたとき、次のような攻撃を受けます。

- メール
- ネット通販
- SNS
- 銀行・証券
- クラウドサービス
- 通信会社

特に、メールアカウントのパスワードを他のサービスと共用してはいけません。メールを乗っ取られると、他のサービスのパスワード再設定まで悪用される可能性があります。

1.3 3. 作成時に重視するポイント 10 個

1. サービスごとに完全に異なるものにする
2. できるだけ長くする
 - パスワードなら 16 文字以上を目安にする
 - パスフレーズなら 20 文字以上、またはランダムな単語を 5 個以上使う
3. パスワードマネージャーでランダム生成する
4. 氏名、誕生日、住所、電話番号を使わない
5. 家族、ペット、好きな芸能人など、推測されやすい情報を使わない
6. Password、123456、qwerty などを使わない
7. 単純な文字置換を過信しない
 - Password を P@ssw0rd にするだけでは不十分
8. 辞書にある単語 1 個だけを使わない

	パスフレーズの例	記憶法の例
1	灯台-銀河-湯気-狸-482!	灯台から銀河を見て、湯気の中の狸を想像する
2	珈琲_青空_羅針盤_鯨_731#	青空の下、羅針盤を持った鯨と珈琲を結びつける
3	桜/時計/砂漠/電車/906?	砂漠を走る電車の中で桜と時計を見る場面を想像する
4	雪山+林檎+望遠鏡+舟+264!	雪山から望遠鏡で舟と林檎を見る場面を想像する
5	青磁-雨-紙飛行機-狐-518%	雨の日に青磁の皿から紙飛行機を飛ばし、狐が追う
6	火山_鈴_麦畑_潜水艦_847&	麦畑の下を潜水艦が進み、火山の鈴が鳴る場面を想像する
7	月面:蜜柑:橋:鶴:392!	月面の橋を鶴が渡り、蜜柑が浮かぶイメージにする
8	庭園=磁石=雨傘=猫=675#	磁石で猫と雨傘が庭園に集まる場面を思い浮かべる
9	氷河-太鼓-葡萄-気球-159?	氷河の上で太鼓を鳴らし、葡萄を持って気球に乗る
10	竹林_汽笛_星座_豆_804!	竹林で汽笛を聞きながら星座と豆を見る物語にする

9. 他人に見せた例や、この文書の例をそのまま使わない

10. 多要素認証またはパスキーを有効にする

文字の種類を増やすことも有効ですが、短い文字列を無理に複雑にするより、**長さ**と**サービスごとの使い分け**を優先してください。

1.4 4. パスフレーズと記憶法の例

以下は仕組みを説明するための例です。**すべて公開済みなので、実際には使用しないでください。**

ただし、人間が自分で選んだ単語には、本人の好みや生活情報から推測される危険があります。実際には、次の方法がより安全です。

- パスワードマネージャーでランダムな文字列を生成する
- パスフレーズ生成機能でランダムな単語を選ぶ
- 生成したものを暗記しようとせず、安全に保存する

1.5 5. 記憶力に自信がない場合の保管方法

1.5.1 1. パスワードマネージャーを使う

最もおすすめです。

- すべてのパスワードを暗号化して保管できる
- 自分で覚えるのはマスターパスワード1つだけでよい
- サービスごとに異なるパスワードを自動生成できる
- 製品によっては、入力時に偽サイトを見分けやすい

マスターパスワードは、十分に長いパスフレーズにし、他のサービスでは使わないでください。

1.5.2 2. 紙に書いて安全な場所に保管する

紙に書くこと自体は、必ずしも危険ではありません。

- 自宅の鍵のかかる場所に置く
- 机の上や財布には置かない
- 写真を撮ってスマートフォンに保存しない
- 他人に見せない

1.5.3 3. 重要な復旧コードを保管する

多要素認証やパスキーには、復旧コードが発行される場合があります。

- 紙に印刷する
- 金庫などに保管する
- パスワードマネージャーに保存する
- 他人に送らない

復旧コードは、パスワードと同じくらい重要です。

1.5.4 4. 信頼できるクラウド同期を利用する

パスワードマネージャーの暗号化された同期機能を使う方法です。

ただし、次の点を守ってください。

- マスターパスワードを使い回さない
- 多要素認証を設定する
- 公式アプリだけを使う
- 偽のサポート画面に入力しない

1.5.5 5. 緊急時の引き継ぎ方法を決める

銀行や重要アカウントについては、信頼できる家族に「保管場所」や緊急時の手順だけを伝える方法があります。

パスワードそのものをメールやメッセージで送るのは避けてください。

1.6 6. パスワードはどのくらいの期間で変更すべきか

1.6.1 基本方針

問題がなければ、定期的に機械的な変更を強制する必要はありません。

以前は「30日ごと」「90日ごと」といった変更が推奨されることがありました。しかし、頻繁な変更を強制すると、次のような問題が起きます。

- Password1、Password2 のような推測しやすい変更になる
- 紙に貼って保管する人が増える
- 同じパスワードを別のサービスでも使ってしまう

1.6.2 すぐ変更すべき場合

次の場合は、期間に関係なく直ちに變更してください。

- パスワードを他人に知られた可能性がある
- フィッシングサイトに入力した
- サービスから情報漏えいの通知を受けた
- 不審なログイン通知が来た
- 同じパスワードを複数サービスで使っていた
- パスワードマネージャーや端末が不正アクセスされた可能性がある

變更するときは、似た文字列にせず、**完全に新しくランダムなもの**にしてください。

1.7 7. 最低限やっておくとよいこと

まず、次の順番で設定することをおすすめします。

1. メールアカウントに固有の強いパスワードを設定する
2. メール、銀行、証券、通販、SNS で多要素認証を有効にする
3. パスワードマネージャーを導入する
4. 使い回しているパスワードをサービスごとに変更する
5. 対応しているサービスではパスキーを登録する
6. 復旧用メールアドレスと電話番号を確認する
7. 復旧コードを安全に保管する
8. 不審なメールや電話でパスワードを伝えない

最も大切なのは、複雑なパスワードを暗記することではありません。アカウントごとに異なる認証情報を使い、パスワードマネージャーやパスキー、多要素認証を組み合わせることです。